INCIDENT INVESTIGATION REPORT SOC | FORENSIC ANALYSIS

Forensic Investigation of SSL VPN Compromise, Lateral Movement, and Local Process Discovery
Author: Esteban Rafael Espitia Coba
Role: SOC Analyst Tier 1 / Threat Hunter
Date of Analysis: August 2024
Monitoring Platform: Wazuh SIEM / OpenSearch Dashboards
Log Sources: Fortigate Firewall Syslog, Linux Kernel Audit (auditd)
Event Timeframe: Aug 01, 2024 00:00 - Aug 07, 2024 00:00 UTC

1. EXECUTIVE SUMMARY

During the monitored timeframe, an intruder launched a targeted brute-force campaign against external SSL VPN endpoints, successfully compromising valid user credentials.
After establishing an authenticated VPN session from an external IP address in Mexico, the threat actor received an internal virtual tunnel IP (10.34.1.13). Using this elevated perimeter position, the adversary probed internal targets, bypassed firewall controls to establish an SSH connection to an application server (10.10.10.11), and conducted local process discovery (ps -aux | grep proftp) via system execution tracking monitored by Linux auditd.

2. METADATA & COMPROMISED ASSETS

Asset / Environment	IP Address	Function	OS / Infrastructure
External Threat Actor	9.2.4.47 (Brute Force) / 189.221.34.106 (Session)	External Attack Vector	Bulgaria / Mexico GeoIP
Edge Gateway	Perimetric Firewall	FortiGate SSL VPN Gateway	FortiOS
Assigned Tunnel IP	10.34.1.13	Virtual VPN Interface	Dynamic Internal Lease
Target App Server	10.10.10.11	Internal Application	Rocky / RHEL Linux

	(agent.name: app1)	Host	

3. INCIDENT TIMELINE

[03/Aug/2024 04:43:00 UTC] ➔ Repeated SSL VPN authentication failures logged for account 'adm_eric' (Origin: Bulgaria).
[06/Aug/2024 18:52:05 UTC] ➔ Successful SSL VPN authentication for 'adm_eric' from Mexico (remip: 189.221.34.106).
[06/Aug/2024 18:52:05 UTC] ➔ Firewall establishes tunnel interface and assigns internal virtual IP 10.34.1.13.
[06/Aug/2024 19:00:00 UTC] ➔ Internal traffic forward: SSH connection (port 22) denied to 10.10.10.4 from 10.34.1.13.
[06/Aug/2024 19:00:00 UTC] ➔ Forwarding rule permits SSH connections to 3 internal destination IPs (10.10.10.9, 10.10.10.10, 10.10.10.11).
[06/Aug/2024 19:03:00 UTC] ➔ Linux auditd captures 'ps -aux | grep proftp' command on host 'app1' (10.10.10.11) under root privileges.

4. DETAILED FORENSIC ANALYSIS BY STAGE

Stage 1: Credential Access via SSL VPN Brute-Force

- **Finding:** High-volume authentication failure alerts were generated for the corporate user account adm_eric.
- **Telemetry Data:** Anomalous login activity originated from non-standard geographic locations (srccountry: Bulgaria).
- **Wazuh Filter Syntax:** rule.groups: firewall AND data.subtype: vpn AND rule.groups: authentication_failed
- **Evidence (Log Snippet):**
  JSON
  "data": {
  "logdesc": "SSL VPN login fail",
  "subtype": "vpn",
  "dstuser": "adm_eric",
  "ip": "9.2.4.47",
  "srccountry": "Bulgaria",
  "action": "ssl-login-fail"
  }

Stage 2: Perimeter Intrusion & Tunnel Establishment

- **Finding:** Following the password-guessing attempt, a successful VPN authentication event (tunnel-up) was recorded for account adm_eric originating from an IP in Mexico (189.221.34.106). The FortiGate gateway assigned virtual interface IP 10.34.1.13.
- **Wazuh Filter Syntax:** data.subtype: vpn AND rule.groups: authentication_success AND data.dstuser: adm_eric AND NOT data.srccountry: Germany
- **Evidence (Log Snippet):**
  JSON
  "data": {
  "logdesc": "SSL VPN tunnel up",
  "subtype": "vpn",
  "dstuser": "adm_eric",
  "ip": "189.221.34.106",
  "srccountry": "Mexico",
  "action": "tunnel-up"
  },
  "full_log": "date=2024-08-06 time=18:52:05 ... remip=189.221.34.106 srccountry=\"Mexico\" tunnelip=10.34.1.13 user=\"adm_eric\" msg=\"SSL tunnel established\""

Stage 3: Internal Traffic Pivoting & Segment Exploration

- **Finding:** Using 10.34.1.13, the attacker attempted lateral movement across internal network resources over port 22 (SSH). Traffic logs show that while access to 10.10.10.4 was dropped (action: deny), access was granted to **3 unique destinations** (10.10.10.9, 10.10.10.10, and 10.10.10.11).
- **Wazuh Filter Syntax:** NOT data.subtype: vpn AND rule.groups: firewall AND data.srcip: 10.34.1.13 AND data.action: allow AND data.service: SSH
- **Evidence (Log Snippet):**
  JSON
  "data": {
  "srcip": "10.34.1.13",
  "dstip": "10.10.10.11",
  "dstport": "22",
  "service": "SSH",
  "action": "allow",
  "subtype": "forward"
  }

Stage 4: Post-Exploitation Process Discovery (Host Audit)

- **Finding:** Once interactive SSH access was established on host app1 (10.10.10.11), kernel-level auditing (auditd) intercepted system call 59 (execve). The attacker executed ps -aux | grep proftp to check for active FTP services (proftpd) on the compromised host.
- **Wazuh Filter Syntax:** agent.name: app1 AND rule.groups: audit AND rule.mitre.id: T1057
- **Evidence (Log Snippet - Linux auditd):**
  JSON

  ```
  "audit": {
    "syscall": "59",
    "command": "ps",
    "execve": {
      "a0": "ps",
      "a1": "-aux",
      "a2": "|",
      "a3": "grep",
      "a4": "proftp"
    },
    "uid": "0",
    "key": "susp_activity"
  }
  ```


5. MITRE ATT&CK MAPPING

Tactic	Technique ID	Technique Name	Description
Credential Access	T1110	Brute Force	Multiple failed SSL VPN login attempts against administrative accounts.
Initial Access / Defense Evasion	T1078	Valid Accounts	Use of valid adm_eric credentials to bypass external perimeter controls.
Lateral Movement	T1021.004	Remote Services: SSH	Pivoting from VPN tunnel interface 10.34.1.13 to host 10.10.10.11.

Discovery	T1057	Process Discovery	Execution of `ps -aux

6. VULNERABILITIES & RECOMMENDATIONS

System Vulnerabilities Identified

1. **Lack of Multi-Factor Authentication (MFA):** External VPN endpoints rely solely on single-factor passwords, leaving them vulnerable to credential spraying and brute-force attacks.
2. **Missing Geo-Fencing Policies:** Incoming administrative VPN connections were permitted from non-standard geographic locations without step-up authentication.
3. **Excessive Internal VPN Access Permissions:** The assigned VPN tunnel segment allowed direct SSH connections to multiple internal servers (10.10.10.0/24) without strict micro-segmentation.

Mitigation & Remediation Action Plan

- **Enforce MFA on Remote Access:** Require Multi-Factor Authentication (MFA) for all SSL VPN connections, specifically for high-privilege administrative users (adm_*).
- **Implement Geo-IP Restrictions:** Configure FortiGate firewall rules to restrict VPN access exclusively to authorized operational regions.
- **Strict Network Micro-Segmentation:** Restrict VPN tunnel traffic using zero-trust policies so remote connections can only reach required internal assets instead of entire subnets.
- **Enable SOC Detection Rules for Discovery Commands:** Maintain Wazuh alerts on auditd logs monitoring process discovery execution (ps, netstat, whoami, ss) performed by elevated interactive sessions.